

CO3_AT3

Course Code: ITA1412

Course: Ethical Hacking

Student Name: ch jaswanth

Register Number:192372199

QUESTION 1

EXTERNAL RECONNAISSANCE USING THEHARVESTER

Aim

To examine the publicly available footprint of the authorized domain **tesla.com** using theHarvester and determine what information can be obtained through passive reconnaissance techniques.

Tool Required theHarvester Target Domain tesla.com

Purpose of the Experiment

The purpose of this exercise is to understand how information published on public sources can reveal details about an organization's external infrastructure. The collected information can then be categorized and evaluated from a security perspective.

Methodology

TheHarvester was executed against the authorized domain to collect information available through supported public sources. The reconnaissance focused on identifying:

- Public email addresses
- Subdomains
- Hostnames
- IP addresses
- URLs
- Domain-related infrastructure
- Other publicly indexed information

Command Executed

theHarvester -d tesla.com -b all

```
kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
[kali@kali]~
$ theHarvester -h
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* THE HARVESTER *
*               *
* theHarvester 4.10.1 *
* Coded by Christian Martorella *
* Edge-Security Research *
* cmartorella@edge-security.com *
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s] [--screenshot SCREENSHOT] [-e DNS_SERVER] [-t]
                  [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME] [-w WORDLIST] [-a] [-q] [-b SOURCE]

theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

options:
  -h, --help                show this help message and exit
  -d, --domain DOMAIN        Company name or domain to search.
  -l, --limit LIMIT          Limit the number of search results, default=500.
  -s, --start START          Start with result number X, default=0.
  -p, --proxies              Use proxies for requests, enter proxies in proxies.yaml.
  -s, --shodan              Use Shodan to query discovered hosts.
  --screenshot SCREENSHOT   Take screenshots of resolved domains specify output directory: --screenshot output_directory
  -e, --dns-server DNS_SERVER DNS server to use for lookup.
  -t, --take-over            Check for takeovers.
  -r, --dns-resolve [DNS_RESOLVE] Perform DNS resolution on subdomains with a resolver list or passed in resolvers, default False.
  -n, --dns-lookup          Enable DNS server lookup, default False.
  -c, --dns-brute           Perform a DNS brute force on the domain.
  -f, --filename FILENAME   Save the results to an XML and JSON file.
  -w, --wordlist WORDLIST   Specify a wordlist for API endpoint scanning.
  -a, --api-scan            Scan for API endpoints.
  -q, --quiet              Suppress missing API key warnings and reading the api-keys file.
  -b, --source SOURCE       baidu, bevigil, bitbucket, brave, bufferoverrun, builtwith, censys, certspotter, chaos, commoncrawl,
                           criminalip, crtsh, dehashed, dosdumpster, duckduckgo, fofa, fullhunt, github-code, gitleab,
                           hackertarget, haveibeenpwned, hudsonrock, hunter, hunterhow, intelx, leakix, leaklookup, netlas,
                           onyphe, otx, pentesttools, projectdiscovery, rapiddns, robtex, rocketreach, securityscorecard,
                           securityTrails, shodan, subdomaincenter, subdomainfinder99, thc, threatcrowd, tomba, urlscan,
                           venacius, virustotal, waybackarchive, whoisxml, windvane, yahoo, zoomeye
```

```
kali@kali: ~
Session Actions Edit View Help
[kali@kali]~
$ theHarvester -d tesla.com -b bing
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* THE HARVESTER *
*               *
* theHarvester 4.10.1 *
* Coded by Christian Martorella *
* Edge-Security Research *
* cmartorella@edge-security.com *
*****
The following engines are not supported: {'bing'}
[!] Invalid source.

[kali@kali]~
$ theHarvester -d tesla.com -b duckduckgo
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* THE HARVESTER *
*               *
* theHarvester 4.10.1 *
* Coded by Christian Martorella *
* Edge-Security Research *
* cmartorella@edge-security.com *
*****

[*] Target: tesla.com
[*] Searching Duckduckgo.
[*] No IPs found.
[*] No emails found.
```

```
[*] Target: tesla.com

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[*] Searching Hackertarget.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] Hosts found: 69
accounts.tesla.com:23.197.44.49
akamai-apigateway-vehicleextinfo-gw-prdsvc-st.tesla.com:23.62.104.69
ams13-gpwl.tesla.com:199.120.50.30
apac-cppm.tesla.com:23.203.50.97
apf-api.eng.vn.cloud.tesla.com:66.17.30.30
apf-api.prd.vn.cloud.tesla.com:66.17.30.32
assets-1r.tesla.com:23.62.104.69
auth.eng.usw.vn.cloud.tesla.com:66.17.6.18
auth.prd.euwl.vn.cloud.tesla.com:52.211.84.165
auth.prd.usw.vn.cloud.tesla.com:66.17.6.74
auth.tesla.com:23.62.10.65
autodiscover.tesla.com:52.96.88.216
bettertime-stage.tesla.com:23.201.167.218
bettertime.tesla.com:23.201.167.218
billing.tesla.com:23.62.104.69
bolt.tesla.com:23.62.10.65
cdn-design.tesla.com:23.62.104.69
charging-transparency.tesla.com:23.45.192.65
click.emails.tesla.com:13.111.48.178
courses.tesla.com:23.62.104.69
```

Recommendations

The organization should maintain an external asset inventory and regularly review publicly available information. Unused domains and subdomains should be removed. Employee information should be exposed only when necessary, and externally accessible services should be properly secured.

Continuous monitoring of public-facing assets can also help identify unexpected exposure.

Conclusion

The exercise showed that passive reconnaissance can provide useful information without directly interacting with internal systems. Organizations should therefore consider public information disclosure as part of their overall attack-surface management strategy.

QUESTION 2

SERVER ANALYSIS USING NIKTO Aim

To examine the security posture of the authorized web application **testphp.vulnweb.com** using Nikto and identify possible weaknesses related to web-server configuration, exposed resources, HTTP methods, and information disclosure.

Tool Required Nikto

Target testphp.vulnweb.com

Methodology

Nikto was used to perform automated checks against the authorized web server. The scan output was reviewed to identify findings that may require further investigation.

The assessment considered:

- Server information
- Exposed files
- Accessible directories
- HTTP methods
- Configuration problems
- Potentially outdated software
- Information-disclosure issues **Command Executed**

zonetransfer.me CNAME **Text Records** dig zonetransfer.me TXT **Start of Authority** dig

zonetransfer.me SOA

Zone Transfer Verification

After identifying the authoritative server: dig AXFR

zonetransfer.me @<authoritative-server>

```
Session Actions Edit View Help
rsh: corrupt history file /home/kali/.rsh_history
--(kali@kali)~
$ dig
DIG 9.20.23-1-Debian
--(kali@kali)~
$ dig zonetransfer.me A
1 <<>> DIG 9.20.23-1-Debian <<>> zonetransfer.me A
2 global options: <cmd>
3 Got answer:
4 --HEADER-- opcode: QUERY, status: FORMERR, id: 19481
5 flags: qr rd QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
6 WARNING: recursion requested but not available
7
8 OPT PSEUDOSECTION:
9 EDNS: version: 0, flags: udp: 1232
10 COOKIE: 4e021331a4133512 (echoed)
11 QUESTION SECTION:
12 zonetransfer.me.          IN      A
13
14 Query time: 8 msec
15 SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
16 WHEN: Mon Aug 10 05:20:16 EDT 2020
17 MSG SIZE rcvd: 56
18
19 --(kali@kali)~
20 $ dig zonetransfer.me AAAA
1 <<>> DIG 9.20.23-1-Debian <<>> zonetransfer.me AAAA
2 global options: <cmd>
3 Got answer:
4 --HEADER-- opcode: QUERY, status: FORMERR, id: 7394
5 flags: qr rd QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
6 WARNING: recursion requested but not available
7
8 OPT PSEUDOSECTION:
9 EDNS: version: 0, flags: udp: 1232
10 COOKIE: 668ead888041624 (echoed)
11 QUESTION SECTION:
12 zonetransfer.me.          IN      AAAA
13
14 Query time: 296 msec
15 SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
16 WHEN: Mon Aug 10 05:20:43 EDT 2020
17 MSG SIZE rcvd: 56
```

```
kali@kali: ~  
Session Actions Edit View Help  
;<<> Dig 9.20.23-1-Debian <<> zonetransfer.me MX  
;; global options: +cmd  
;; Got answer:  
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 36525  
;; Flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1  
;; WARNING: recursion requested but not available  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags:; udp: 1232  
; COOKIE: eed840a01b8807e3 (echoed)  
;; QUESTION SECTION:  
;zonetransfer.me.          IN      MX  
  
;; Query time: 24 msec  
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)  
;; WHEN: Mon Aug 10 05:20:55 EDT 2026  
;; MSG SIZE rcvd: 56  
  
(kali@kali)-[~]  
$ dig zonetransfer.me NS  
  
;<<> Dig 9.20.23-1-Debian <<> zonetransfer.me NS  
;; global options: +cmd  
;; Got answer:  
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 48016  
;; Flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1  
;; WARNING: recursion requested but not available  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags:; udp: 1232  
; COOKIE: 28e75b0658e7b49 (echoed)  
;; QUESTION SECTION:  
;zonetransfer.me.          IN      NS  
  
;; Query time: 52 msec  
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)  
;; WHEN: Mon Aug 10 05:21:02 EDT 2026  
;; MSG SIZE rcvd: 56
```

```
kali@kali: ~  
Session Actions Edit View Help  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags:; udp: 1232  
; COOKIE: 8c08c75cddcfaf2e (echoed)  
;; QUESTION SECTION:  
;zonetransfer.me.          IN      SOA  
  
;; Query time: 16 msec  
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)  
;; WHEN: Mon Aug 10 05:21:14 EDT 2026  
;; MSG SIZE rcvd: 56  
  
(kali@kali)-[~]  
$ dig zonetransfer.me TXT  
  
;<<> Dig 9.20.23-1-Debian <<> zonetransfer.me TXT  
;; global options: +cmd  
;; Got answer:  
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 6358  
;; Flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1  
;; WARNING: recursion requested but not available  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags:; udp: 1232  
; COOKIE: a74ccccc69e6134f (echoed)  
;; QUESTION SECTION:  
;zonetransfer.me.          IN      TXT  
  
;; Query time: 32 msec  
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)  
;; WHEN: Mon Aug 10 05:21:22 EDT 2026  
;; MSG SIZE rcvd: 56
```

Verification of Fix

After restricting zone transfers, an AXFR request should be tested again from an unauthorized location. The expected result should be refusal of the transfer while authorized DNS replication continues to work normally.

Conclusion

The DNS assessment demonstrated that DNS records can provide considerable information about an organization's infrastructure. Restricting zone transfers and maintaining clean, accurate DNS records can reduce unnecessary information disclosure.

QUESTION 4 – WINDOWS SMB ENUMERATION USING ENUM4LINUX Aim

To analyze the SMB and NetBIOS exposure of the authorized Windows system **192.168.1.100** using Enum4linux and determine what information is available without attempting exploitation.

Tool Required Enum4linux

Target

192.168.1.100

Objective

The exercise focuses on identifying information such as:

- Windows system details
- Users
- Groups
- Shared folders
- Domain/workgroup information
- Password policy
- NetBIOS information
- SMB configuration details

```
kali@kali:~$ zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ ./enum4linux -h
enum4linux v0.9.1 (http://labs.portcullis.co.uk/application/enum4linux/)
Copyright (C) 2011 Mark Lowe (wrl@portcullis-security.com)

Simple wrapper around the tools in the samba package to provide similar
functionality to enum.exe (formerly from www.bindview.com). Some additional
features such as RID cycling have also been added for convenience.

Usage: ./enum4linux.pl [options] ip

Options are (like "enum"):
-U get userlist
-M get machine list
-S get sharelist
-P get password policy information
-G get group and member list
-d be detailed, applies to -U and -S
-u user specify username to use (default "")
-p pass specify password to use (default "")

The following options from enum.exe aren't implemented: -L, -N, -D, -f

Additional options:
-a Do all simple enumeration (-U -S -G -P -r -u -n -i).
  This option is enabled if you don't provide any other options.
-h Display this help message and exit
-r enumerate users via RID cycling
-R range RID ranges to enumerate (default: 500-509,1000-1050, implies -r)
-k n Keep searching RIDs until n consecutive RIDs don't correspond to
  a username. Implies RID range ends at 999999. Useful
  against DCs.
-l Get some (limited) info via LDAP 389/TCP (for DCs only)
-s file brute force guessing for share names
-k user User(s) that exists on remote system (default: administrator,guest,krbtgt,domain admins,root,bin,none)
  Used to get sid with "lookupsid known_username"
  Use commas to try several users: "-k admin,user1,user2"
-o Get OS information
-i Get printer information
-w wrkg Specify workgroup manually (usually found automatically)
-n Do an nblookup (similar to nbtstat)
-v Verbose. Shows full commands being run (net, rpcclient, etc.)
-A Aggressive. Do write checks on shares etc
```

```
kali@kali:~$ ./enum4linux 192.168.1.100
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:23:18 2026

( Target Information )
Target ..... 192.168.1.100
RID Range ..... 500-509,1000-1050
Username ..... ""
Password ..... ""
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

( Enumerating Workgroup/Domain on 192.168.1.100 )
(E) Can't find workgroup/domain

( NBTstat Information for 192.168.1.100 )
Looking up status of 192.168.1.100
No reply from 192.168.1.100

( Session Check on 192.168.1.100 )
(E) Server doesn't allow session using username "" password "". Skipping remainder of tests.
```

Commands Used

Comprehensive Enumeration

enum4linux -a 192.168.1.100

User Enumeration enum4linux

-U 192.168.1.100 Group

Enumeration enum4linux -G

192.168.1.100 Share

Enumeration enum4linux -S

192.168.1.100 Operating-

System Details enum4linux -o

192.168.1.100 Password

Policy enum4linux -P

192.168.1.100 **NetBIOS**

Details enum4linux -n

192.168.1.100

Remediation Validation

Enum4linux should be executed again after the security changes. The organization should verify that unnecessary users, groups, shares, and configuration information are no longer accessible to unauthorized users.

Conclusion

The assessment demonstrated the importance of securing SMB and NetBIOS services. Excessive enumeration information can assist attackers during later stages of an attack. Proper access control, network segmentation, authentication, and secure SMB configuration can reduce these risks.

QUESTION 5 – TCP SERVICE ENUMERATION USING NETCAT Aim

To use Netcat to communicate with an authorized TCP service on **scanme.nmap.org** and examine the information returned by the service for banner and technology identification.

Tool Required Netcat (nc) **Target** scanme.nmap.org **Purpose**

The exercise is designed to understand how service responses can expose information about protocols, server technologies, HTTP headers, and implementation details.

Procedure

A verbose TCP connection was established to the authorized HTTP service.

```
nc -v scanme.nmap.org 80
```

An HTTP request was then submitted:

```
GET / HTTP/1.1
```

```
Host: scanme.nmap.org
```

```
Connection: close
```

Analysis

A service banner can reveal information about the software and protocol running on a particular port. HTTP headers can also expose implementation details.

From a defensive perspective, the disclosure of a software version is not necessarily a vulnerability. However, the information may make fingerprinting easier. An attacker could potentially compare an identified software version against known vulnerability databases and determine whether additional investigation is justified.

Therefore, any suspected vulnerability must be manually verified before being classified as confirmed.

```
kali@kali ~$ ssh: corrupt history file /home/kali/.zsh_history
kali@kali~$ nc -h
[vi.10-50.1]
connect to somewhere: nc [-options] hostname port[s] [ports] ...
listen for inbound: nc -l -p port [-options] [hostname] [port]
options:
-c shell commands          as '-e'; use /bin/sh to exec [dangerous!!]
-e filename                program to exec after connect [dangerous!!]
-b                          allow broadcasts
-g gateway                 source-routing hop point[s], up to 8
-m num                     source-routing pointer: 4, 8, 12, ...
-i secs                    delay interval for lines sent, ports scanned
-k                          set keepalive option on socket
-l                          listen mode, for inbound connects
-n                          numeric-only IP addresses, no DNS
-o file                     hex dump of traffic
-p port                    local port number
-r                          randomize local and remote ports
-q secs                    quit after EOF on stdin and delay of secs
-s addr                    local source address
-T tos                      set Type Of Service
-t                          answer TELNET negotiation
-u                          UDP mode
-v                          verbose [use twice to be more verbose]
-w secs                    timeout for connects and final net reads
-C                          Send CRLF as line-ending
-z                          zero-I/O mode [used for scanning]

port numbers can be individual or ranges: lo-hi [inclusive];
hyphens in port names must be backslash escaped (e.g. 'ftp-data').

kali@kali~$ nmap scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 07:33 -0400
Failed to resolve "scanme.nmap.org".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 4.59 seconds

kali@kali~$ nc scanme.nmap.org 80
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable

kali@kali~$ nc scanme.nmap.org 443
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable

kali@kali~$ nc scanme.nmap.org 80
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable

kali@kali~$ nc scanme.nmap.org 443
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable

kali@kali~$ nc scanme.nmap.org 22
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable
```

Remediation Verification

After applying the required configuration changes, the service should be contacted again using an approved tool. The response should be compared with the original result to confirm that unnecessary information has been reduced.

Conclusion

Netcat demonstrated that even a basic TCP connection can reveal useful information about a service. Service-banner exposure is primarily an information-disclosure concern, but it can make subsequent attacks more focused. Regular service reviews, patch management, access restrictions, and careful configuration can reduce the available information.